



ICT Incident & Operational Event Management Guideline

Version: 2.0

Valid From Date: 19.08.2026

Last Review Date: 14.08.2026

Notes: This written rule uses gender-neutral and inclusive language. Whenever possible, the generic masculine is avoided and all employees of any gender identity (m/f/d) are addressed.

Content changes compared to the previous document version are highlighted in color.

Content

1. Purpose, Objectives and Basis	3
1.1. Purpose and Objectives	3
1.2. Basis of this Guideline	4
2. Functional Scope and Target Groups	5
2.1. Functional scope of applicability	5
2.2. Target groups	5
2.3. Transition period	6
3. Definitions	7
3.1. Requirements	7
3.2. Explanation of requirements and key definitions	8
3.3. Major ICT-related Incident	8
4. Requirements	9
4.1. Requirement	9
5. Roles and Responsibilities	30
5.1. Creator	30
5.2. Guideline Owner	30
6. Appendix	31
6.1. Contact Information	31
6.2. Document History	31
6.3. Related Written Rules	31
6.4. Abbreviations	32

1. Purpose, Objectives and Basis

1.1. Purpose and Objectives

The ICT Incident & Operational Event Management Guideline (hereinafter “Guideline”) establishes control requirements for DBAG and/or adopting Legal Entities within DBG (refers only to Legal Entities that have ratified the Guideline at hand) and provides criteria for fulfilling the control requirements.

The purpose of the Guideline is to effectuate the below listed Minimum Requirements, stipulated in the ICT Risk Management Policy (structured into Core Functions), acting as objectives to the Guideline and the control requirements at hand:

Core Function	Minimum Requirement	ICT Risk Management Policy chapter
Govern	2. Allocate roles and responsibilities as detailed in chapter 5 in this policy	4.1
Govern	6. Have in place a mechanism to define and document responsibilities for implementing control requirements both within and outside IT and IS (e.g. HR). This can be documented e.g. as part of the ICT Control Framework (former Mandatory Control Framework (MCF)) .	4.1
Govern	9. Establish and maintain contact with special interest groups or other specialist security forums and professional associations.	4.1
Detect	1. Define, implement, monitor, and regularly test detection processes and mechanisms to promptly detect anomalous activities including network performance issues and ICT-related incidents, and identify potential material single points of failure.	4.4
Detect	2. Put in place sufficient capabilities to monitor user activity, the occurrence of anomalous events, in particular cyber-attacks.	4.4
Respond	2. Define, implement, and test response processes and mechanisms to ensure ICT-related Incident containment, to prevent expansion of an event and mitigate its effects.	4.5
Respond	3. Assess ICT security events and decide if they are to be categorized as ICT-related incidents.	4.5
Respond	4. Establish and implement procedures for the identification, collection, acquisition, and preservation of	4.5

	evidence related to ICT-related Incidents.	
Recover	1. Define, execute, and regularly test continuity and recovery plans to recover from ICT-related incidents in a way that limits damage and prioritizes the continuation and resumption of activities.	4.6
Communicate	1. Set out communication and crisis management actions to ensure that updated information is transmitted to all relevant internal staff and external stakeholders and reported to the competent authorities upon their request.	4.8

Table 1: Minimum Requirements

Note: The full list of Core Functions and Minimum Requirements is stipulated in the ICT Risk Management Policy.

1.2. Basis of this Guideline

The basis for this Guideline is the thematically linked ICT Risk Management Policy.

2. Functional Scope and Target Groups

2.1. Functional scope of applicability

Entity	DBAG or adopting LE within DBG
Area	DBAG CIO / COO Division; Chief Risk Officer Area; or any other area that manages or owns ICT-related Incident and Operational Event Management topic

Table 2: Scope

2.2. Target groups

Within the scope of the current ICT Incident & Operational Event Management Guideline below is addressed the list of applicable target groups and operation areas¹:

Target group	Key message
Management Body	To ensure strategic direction, resources, and support for ICT-related Incident and event management activities.
ICT Operational Management	To implement and manage ICT-related Incident Management tools and procedures and to ensure effective communication and coordination during ICT-related Incidents.
Business Management	To detect, analyze, and respond with ICT-related Incident response plans to ICT-related Incidents, ensuring the security and integrity of systems and data and managing ICT-related Incidents from detection to resolution.
ICT Risk Oversight	To oversee the development, implementation, and enforcement of ICT-related Incident Management policies and procedures and assess the impact of ICT-related Incidents on the organization.
Third Parties	To ensure the compliance with established ICT-related Incident Management standards.
All employees	To be aware of the core principles of this Guideline and to be informed about the roles and responsibilities in reporting and responding to ICT-related Incidents.

Table 3: Target groups

¹ For LE Guidelines adoption process the target groups should be adjusted according to organizational structure of the LE.

2.3. Transition period

The grace period for new requirements commences from the “valid from” date stated on the cover page. The compliance dates for control requirements defined in this version of the Guideline are defined as follows:

- For unchanged control requirements and new DORA requirements the compliance date equals the “valid from” date.
- For new and changed control requirements that are more stringent than before and are not subject to DORA, the compliance date is generally 90 calendar days after the “valid from” date unless otherwise stated in brackets after the control requirements. These control requirements are marked with ●.
- For Legal Entities that have not previously approved the IT-related requirements and are therefore addressing these requirements for the first time, a grace period of 90 days may be granted at the discretion of the Legal Entity. DORA requirements are exempt from this grace period.

For a **compliance date** exceeding a 180 calendar days implementation timeline, a Board approval is required.

3. Definitions

3.1. Requirements

Control requirement

The control requirements define the organizational, process or technical controls to be implemented by the control owner to achieve compliance with this Guideline.

Criteria

Criteria define the measures that 'must' or 'should' be taken to fulfill the control requirement.

Level of obligation

With respect to requirements and criteria, the following terms are used to define the level of obligation, provided for the implementation of a particular requirement or criteria:

- **“must”**: Mandatory control requirements / criteria derived directly from law, regulations, or internal specifications that the legal entity must comply with. Incompliance could result in consequences with external regulators and Internal Audit.
- **“should”**: Non-mandatory control requirements / criteria derived from best-practice frameworks or equivalent sources that the legal entity does not have to necessarily comply with. Under specific circumstances there may exist valid reasons to ignore a particular control requirement, but the full implications must be understood and carefully weighed.

Independent of the level of obligation of a given requirement or criteria, it is allowed to deviate from single requirements or criteria in individual cases. However, a control requirement deviation always requires the conduction of a risk assessment and risk management including adequate risk acceptance and/or mitigation.

Any deviation from the Guideline denotes an exemption. The respective Information Owner makes decisions on such exemptions. Information Owners can only decide on risks with impact exclusively in their area of responsibility.

Responsibilities

The responsibility for fulfilling control requirements may be distributed across the organization, e.g., multiple Sections, Units, or Departments. In some cases, one Unit may be responsible for both the design and implementation of measures. In other cases, one Unit may be responsible for the design of measures, and another Unit may be responsible for the implementation of the measures. In addition, multiple Units may be responsible to collectively fulfill one requirement.

The precise responsibilities are to be defined in the underlying Procedure documents (e.g. via RACI matrices).

The ICS, among its various functionalities, registers Process Operators (PO) and Risk Representatives (RRs) mapped to the corresponding processes, controls, and risks which the RRs and/or POs are responsible for managing on behalf of the part of the organization that utilize their services (e.g. Asset Owners). For more information on ICS, please refer to the DBG ICS Guideline.

3.2. Explanation of requirements and key definitions

Control requirements are defined in a standardized format and are structured into the following components:

<Specify ID: xx (version x)>	<Name of control requirement (e.g. Access to production data)>
1	<Description of the control requirement>
1.1 1.1.1	<Lists the criteria applying to the control requirement> <Lists the sub-criteria applying to the control requirement> Asset-Types: <Lists asset types applicable to the control requirement> Key references: <Lists key regulatory references and industry best practice requirements affecting this control requirement (e.g., ISO/IEC 27001:2022 A.5.10, A.8.1)>

The terms in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

3.3. Major ICT-related Incident

‘Major ICT-related Incident’ means an ICT-related Incident that has a high adverse impact on the ICT Systems that support critical or important functions of the legal entity entity or financial services requiring authorization, registration or supervision in the sense that one of the following three conditions are fulfilled:

- (1) If there is any successful, malicious, and unauthorized access to ICT Systems (in accordance with ID 6.9, 6.13.1) or any impact on availability, authenticity, integrity or confidentiality of data with adverse impact (in accordance with ID 6.8, 6.13.2),
- (2) If two or more of the following categories of conditions are met (in accordance with ID 6.13.2):
 - a. Clients, financial counterparts and transactions (in accordance with ID 6.3, 6.4, 6.5),
 - b. Data loss (in accordance with ID 6.8, 6.13.2),
 - c. Reputational impact (in accordance with ID 6.6),
 - d. Duration and service downtime (in accordance with ID 6.12, 6.13.2),
 - e. Geographical spread (in accordance with ID 6.7),
 - f. Economic impact (in accordance with ID 6.10, 6.13.2), or
- (3) If a recurring incident fulfills the materiality thresholds (in accordance with IDs 6.15).

4. Requirements

4.1. Requirement

ID: 1 (version 2.0)	ICT-related Incident Rules & Procedures
1 DOR.ICT.INC.PRO.001	It must be ensured that ICT-related Incident Rules & Procedures are established and in place.
1.1 DOR.ICT.INC.PRO.002	ICT-related Incident Management rules and procedures must be in place to record all incidents and significant cyber threats, consistently monitor, handle, and follow-up to identify root causes, to document and address them and prevent occurrence of such incidents. Such documents must be reviewed / updated on a regular basis, at least once every 12 months. Asset-Types: Business Process, End User Device Key References: DORA 2022/2554 A.17.2
1.2 DOR.ICT.INC.PRO.003	The ICT-related Incident Management processes must be reviewed on a regular basis, at least every 12 months. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.24
1.3 DOR.ICT.INC.PRO.004	The ICT-related Incident Management process must contain the following: Asset-Types: Business Process Key References: DORA 2022/2554 A.17.3a)
1.3.1 DOR.ICT.INC.PRO.005	Early warning indicators Asset-Types: Business Process Key References: DORA 2022/2554 A.17.3a)
1.3.2 DOR.ICT.INC.PRO.006	Established procedures for identifying, tracking, and categorizing incidents based on priority, severity, and criticality of services and including forensic investigations. Asset-Types: Business Process Key References: DORA 2022/2554 A.17.3b)
1.3.3 DOR.ICT.INC.PRO.007	Assigned roles and responsibilities that need to be activated in different incident types and scenarios to effectively detect and respond to ICT-related Incidents and anomalous activities. Asset-Types: Business Process Key References: DORA 2022/2554 A.17.3c)
1.3.4 DOR.ICT.INC.PRO.008	Communication plan to staff, stakeholders, media, clients, internal escalation procedures. Asset-Types: Business Process Key References: DORA 2022/2554 A.17.3d)
1.3.5 DOR.ICT.INC.PRO.009	Established response procedures to mitigate impacts and ensure services become operational and secure in a timely manner. Asset-Types: Business Process Key References: DORA 2022/2554 A.17.3f)

1.4 DOR.ICT.INC.PRO.010	ICT-related Incident metrics must be established, monitored and analyzed to detect weaknesses in operational processes or technical controls to support effective ICT-related Incident Management. Asset-Types: Business Process Key References: CCM requirement SEF05
1.5 DOR.ICT.INC.PRO.011	Incidents that occur through or in connection with AI systems, that compromise the security of network and information systems and violate IT data protection objectives or have a negative impact on services provided must be recorded as ICT-related incident. Asset-Types: Self-developed DBG Application, Third-party-developed Application, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, No-Code/Low-Code Application, Partner Services, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud IaaS, Cloud PaaS, Virtualization Platform, Database Management System (DBMS) Key References: DORA 2022/2554 A.9
1.6 DOR.ICT.INC.PRO.012	Incidents related to AI systems should also be labeled as AI related. Asset-Types: Self-developed DBG Application, Third-party-developed Application, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, No-Code/Low-Code Application, Partner Services, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud IaaS, Cloud PaaS, Virtualization Platform, Database Management System (DBMS) Key References: ISO 42001 A.6.2.2

ID: 2 (version 2.0)	Additional organizational Capabilities
2 DOR.ICT.INC.ADD.001	It must be ensured that ICT-related Incident Prevention & Preparation is established and in place.
2.1 DOR.ICT.INC.ADD.002	A Security Operations Center must be established that performs real-time monitoring and analysis of security-related events. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Network Connection, Room Key References: ISO 27001:2022 Cor 202203 A.5.26
2.2 DOR.ICT.INC.ADD.003	Incident response capabilities must be present at the organizational level. Asset-Types: Business Process, End User Device Key References: ISO 27001:2022 Cor 202203 A.5.24
2.3 DOR.ICT.INC.ADD.004	The needed skills and training for the staff, that is handling ICT-related Incidents and related data and evidence, must be defined and the relevant staff needs to be aware of their responsibilities and trained accordingly. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.24

ID: 3 (version 2.0)	Event Logging
3 DOR.ICT.INC.EVL.001	It must be ensured that event logging is established and in place.
3.1 DOR.ICT.INC.EVL.002	Logging procedures, protocols and tools must be established and documented. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.12 1)
3.2 DOR.ICT.INC.EVL.003	It must be ensured that measures to detect failure of logging systems are in place. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.12 2d)
3.3 DOR.ICT.INC.EVL.004	Event logging, retention period and measures for securing and handling log data must be elements of the logging procedures. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other

	Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.12 2a)
3.4 DOR.ICT.INC.EVL.005	Event logs must contain further details, aligned on the level of purpose and usage. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.12 2b)
3.5 DOR.ICT.INC.EVL.006	Event Logging must include internal and external factors, including logs gathered in logging procedures, information from business and ICT operations, and any issues reported by the users of the legal entity. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.23.2a.i
3.6 DOR.ICT.INC.EVL.007	If log information is automatically changed/enriched/filtered, it must be ensured that this is done only within the framework of regulated processes and controls. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.15
3.7 DOR.ICT.INC.EVL.008	It must be ensured that the log information of the IT Assets reaches the monitoring solution without delay. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.15
3.8 DOR.ICT.INC.EVL.009	The analyzability of the log data and the availability of the required ICT Systems must be ensured. Log information must be protected against tampering, deletion, and unauthorized access at rest, in transit and in use. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.15
3.9 DOR.ICT.INC.EVL.010	Security-related event logging and monitoring must be implemented and must contain information about user and administrator activities, type of activity, time, and location. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other

	Device, Storage, Server & Host Hardware, Network Connection, Supplier Key References: ISO 27001:2022 Cor 202203 A.8.15
3.10 DOR.ICT.INC.EVL.011	Security-related log, raw and analysis data must be retained in an audit-proof manner through defined log retention periods times in accordance with the applicable regulations. Documentation must be available, including defined retention periods. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.15
3.11 DOR.ICT.INC.EVL.012	An incident logging activity must be described. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ICT Risk Framework 1.0
3.12 DOR.ICT.INC.EVL.013	After detecting anomalous activities relevant information must be logged to enable the identification of the date and time when the activity occurred, the date and time when it was detected, and the type of anomalous activity. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.23.4
3.13 DOR.ICT.INC.EVL.014	All relevant information about the incident must be documented/logged so that a full historical record is maintained in a manner that enables other Service Group(s) to support resolution. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ICT Risk Framework 1.0
3.14 DOR.ICT.INC.EVL.015	Every activity related to the handling of ICT-related Incidents and forensic investigations must be logged and documented. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.24

ID: 4 (version 2.0)	ICT-related Incident and Event Monitoring
4 DOR.ICT.INC.MON.001	It must be ensured that ICT-related Incident and Event Monitoring is established and in place.
4.1 DOR.ICT.INC.MON.002	A security information and event management (SIEM or equivalent at the legal entity) must be implemented and maintained. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Container, Storage, Server & Host Hardware, Network Connection, Supplier Key References: ISO 27001:2022 Cor 202203 A.8.15
4.2 DOR.ICT.INC.MON.003	Mechanisms must be in place to promptly detect anomalous activities, including ICT network performance issues, ICT-related Incidents, and potential material single points of failure. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection, Building, Room, Datacenter Key References: DORA 2022/2554 A.10.1
4.3 DOR.ICT.INC.MON.004	ICT Systems must be monitored for anomalous behavior. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.15
4.4 DOR.ICT.INC.MON.005	A database activity monitoring system (DAM or equivalent at the legal entity) must be implemented and maintained for databases where applicable. Asset-Types: Business Process, Cloud IaaS / Virtual Machines, Server and Host Hardware, DBMS and database Key References: DORA RTS RMF Art. 23.2(a)(iii); ISO/IEC 27001:2022 A.8.16
4.5 DOR.ICT.INC.MON.006	A set of correlation rules (DAM Policies and Pipelines) must be developed, tested, documented, and maintained through a structured lifecycle process to identify anomalous activities and behaviors for databases. Asset-Types: Business Process Key References: DORA RTS RMF Art. 23.3
4.6 DOR.ICT.INC.MON.007	Cyber threat intelligence and behavioral analytics should be used for database events monitoring. Asset-Types: Business Process, Commercial of the Shelf Solution Key References: DORA RTS RMF Art. 23.4; ISO/IEC 27001:2022 A.5.7
4.7 DOR.ICT.INC.MON.008	Detection mechanisms must incorporate multiple layers of control, including the definition of alert thresholds and criteria that trigger ICT-related Incident response processes. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance,

	Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection, Building, Room, Datacenter Key References: DORA 2022/2554 A.10.2
4.8	When defining the criteria that trigger ICT-related Incident response processes, in addition to considering the criticality of the affected services, the following criteria must be considered: - Indications that malicious activity may have occurred in an ICT System or that it may have been compromised. - Detection of data losses affecting the availability, authenticity, integrity, or confidentiality of data. - Detection of adverse impacts on transactions and operations. - Unavailability of ICT Systems. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.23.5, 23.6
4.9 DOR.ICT.INC.MON.009	Automatic alert mechanisms and tools, based on pre-defined rules to identify anomalies, must be established for IT Assets and Non-IT Assets supporting critical or important function to notify relevant staff in charge of ICT-related Incident response when thresholds are met, or anomalies are detected. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection, Building, Room, Datacenter Key References: DORA 2022/2554 A.10.2, A.10.3
4.10 DOR.ICT.INC.MON.011	Anomalous activities and behaviors must be documented, analyzed and evaluated automatically or manually. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection, Building, Room, Datacenter Key References: DORA RTS RMF A.23.2d)
4.11 DOR.ICT.INC.MON.012	It must be ensured that any recording of anomalous activities is protected against tampering and unauthorized access at rest, in transit and, where relevant, in use. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.23.3
4.12 DOR.ICT.INC.MON.013	A set of correlation rules (SIEM use cases) must be developed, tested, documented, and maintained through a structured lifecycle process to identify anomalous activities and behaviors. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance,

	Hardware Appliance, Container, Storage Key References: ISO 27001:2022 Cor 202203 A.8.15
4.13 DOR.ICT.INC.MON.014	All detection mechanisms must be regularly tested. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection, Building, Room, Datacenter Key References: DORA 2022/2554 A.10.1
4.14 DOR.ICT.INC.MON.015	ICT-related Incidents must be monitored along their lifecycle (from creation of the ticket until closure). Asset-Types: Business Process Key References: ICT Risk Framework 1.0
4.15 DOR.ICT.INC.MON.016	It must be ensured that open ICT-related Incidents are resolved, and the tickets closed within defined time frames. Asset-Types: Business Process Key References: ICT Risk Framework 1.0

ID: 5 (version 2.0)	ICT-related Incident Identification
5 DOR.ICT.INC.IDN.001	It must be ensured that ICT-related Incident Identification is established and in place.
5.1 DOR.ICT.INC.IDN.002	There must be a process for determining the priority of an incident based on the impact and urgency assessment. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
5.2 DOR.ICT.INC.IDN.003	Criteria for functional (to the next level of support) and hierarchical escalation (to the next level of management) must be defined in the process. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
5.3 DOR.ICT.INC.IDN.004	The process must escalate unresolved ICT-related Incidents in such a way as to ensure that target resolution and reaction times are not exceeded. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
5.4 DOR.ICT.INC.IDN.005	If the initial investigation and diagnosis activities reveal an incident whose priority requires immediate escalation, it must be appropriately escalated (hierarchical and functional). Asset-Types: Business Process Key References: ICT Risk Framework 1.0
5.5 DOR.ICT.INC.IDN.006	The process must ensure that methods for detecting and reporting ICT-related Incidents are at defined intervals tested. Asset-Types: Business Process Key References: ICT Risk Framework 1.0

ID: 6 (version 2.0)	ICT-related Incident and Threat Classification
6 DOR.ICT.INC.CLS.001	It must be ensured that ICT-related Incident Classification is defined and established.
6.1 DOR.ICT.INC.CLS.002	A process must be established to classify ICT-related Incidents based on their impacts on clients, financial counterparts, transactions, reputational impact, service downtime, geographical spread, data losses, critical services, and economic impact. Asset-Types: Business Process Key References: DORA 2022/2554 A.18.2)
6.2 DOR.ICT.INC.CLS.003	It must be ensured that a specific materiality threshold is defined for each classification criteria to determine when an ICT-related Incident qualifies as a major ICT-related Incident². Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.9 14
6.3 DOR.ICT.INC.CLS.004	The number of the affected clients and financial counterparts must be determined by evaluating those unable to use the service or adversely impacted during the ICT-related Incident, including third parties covered by contractual agreements. Asset-Types: Business Process Key References: DORA 2022/2554 A.18.1.a)
6.4 DOR.ICT.INC.CLS.005	All transactions affected by the ICT-related Incident must be assessed, focusing on those involving monetary amounts and having a part of the transaction within the European Union. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.1.4)
6.5 DOR.ICT.INC.CLS.006	If the exact number of affected clients, counterparts or amount or number of transactions cannot be determined, an estimation must be applied based on available data from comparable reference periods. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.1.5
6.6 DOR.ICT.INC.CLS.007	The impact of the ICT-related Incident on the legal entity's reputation must be determined, taking into account the level of visibility that the incident has gained or is likely to gain, as soon as one of the following conditions is met: Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.2.1.a)
6.6.1 DOR.ICT.INC.CLS.008	The ICT-related Incident has been reflected in the media. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.2.1.a)
6.6.2 DOR.ICT.INC.CLS.009	The legal entity has received repetitive complaints from different clients or counterparts on client-facing services or critical business relationships. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.2.1.b)

² For further details, please refer to the definition in Chapter 3.3.

6.6.3 DOR.ICT.INC.CLS.010	The legal entity will not be able to or is likely not to be able to meet regulatory requirements. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.2.1.c)
6.6.4 DOR.ICT.INC.CLS.011	The legal entity is likely to lose clients or financial counterparts with a material impact on its business as a result of the ICT-related Incident. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.2.1.d)
6.7 DOR.ICT.INC.CLS.012	To determine the geographical spread of an ICT-related Incident, it must be ensured to assess the impact on other EU Member States, specifically considering the significance for: Asset-Types: Business Process Key References: DORA 2022/2554 A.18.1.c)
6.7.1 DOR.ICT.INC.CLS.013	Affected clients and financial counterparts. Asset-Types: Business Process Key References: DORA 2022/2554 A.18.1.c)
6.7.2 DOR.ICT.INC.CLS.014	Branches of the legal entity or related entities within the group. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.4.1.b)
6.7.3 DOR.ICT.INC.CLS.015	Financial market infrastructures or third-party providers that may affect their services. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.4.1.c)
6.8 DOR.ICT.INC.CLS.016	Data losses must be assessed based on their impact on data availability, authenticity, integrity and confidentiality. Asset-Types: Business Process Key References: DORA 2022/2554 A.18.1.d)
6.9 DOR.ICT.INC.CLS.017	The impact on critical services must be assessed by determining whether the ICT-related Incident affected ICT services or ICT Systems that support critical or important functions, involved unauthorized access, or disrupted financial services requiring authorization, registration or supervision. Asset-Types: Business Process Key References: DORA 2022/2554 A.18.1.e)
6.10 DOR.ICT.INC.CLS.018	The economic part of the ICT-related Incident must be assessed by calculating direct and indirect costs, including expropriated funds, replacement costs, staff costs, customer compensation, lost revenue, fees due to non-compliance with contractual obligations, communication costs, and advisory costs (e.g., legal and forensic services). Asset-Types: Business Process Key References: DORA 2022/2554 A.18.1.f)
6.11 DOR.ICT.INC.CLS.019	The costs and losses based on data available at the time of classification must be calculated and if those cannot be determined then the amounts must be estimated. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.7.3)

6.12 DOR.ICT.INC.CLS.019	Costs that are necessary for the day-to-day operation of the business (e.g., general maintenance, standard staff costs not dedicated to the incident response) must be excluded from the calculation of costs and losses Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.7.3)
6.13 DOR.ICT.INC.CLS.020	The ICT-related Incident duration must be measured from its occurrence (if the occurrence is unknown, the time starts with the detection) until resolution. Service downtime must be measured from when the service becomes fully or partially unavailable until normal operations are fully restored. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.3.1)
6.14 DOR.ICT.INC.CLS.021	The ICT-related Incident must be considered as a major ICT-related Incident² if it has had any impact on critical services and either of the following conditions is fulfilled: Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.8.1
6.14.1 DOR.ICT.INC.CLS.022	The ICT-related Incident has involved any successful malicious unauthorized access to ICT Systems, potentially resulting in data losses. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.9.5
6.14.2 DOR.ICT.INC.CLS.023	Or thresholds of at least two of the following conditions are met: - If any of the reputational impact conditions that are stated in ID 6.6 occurred. - If more than 10% of clients (or more than 100,000 clients) or 30% financial counterparts are affected. - If more than 10% of daily transactions (by number or value) are affected. - If the ICT-related Incident lasts longer than 24 hours. - If service downtime exceeds 2 hours for critical services. - If the ICT-related Incident impacts at least two EU Member States. - Data loss affecting business objectives or regulatory compliance. - Costs and losses incurred exceed or are likely to exceed €100,000. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.9.5
6.15 DOR.ICT.INC.CLS.024	A process must be established to track recurring ICT-related Incidents, and the existence of recurring ICT-related Incidents must be assessed monthly. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.15.1), A.15.2)
6.16 DOR.ICT.INC.CLS.025	Recurring ICT-related Incidents, that occur at least twice within six months, share the same root cause and also affecting critical business processes must be classified as a major ICT-related Incident². The ICT-related Incidents must be also evaluated against the materiality threshold for major ICT-related Incidents. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.15.1)

ID: 7 (version 2.0)	ICT-related Incident Analysis
7 DOR.ICT.INC.ANL.001	It must be ensured that ICT-related Incident Analysis procedures are established and in place.
7.1 DOR.ICT.INC.ANL.002	Alerts or IS events must be analyzed and prioritized to confirm whether they are to be categorized as an ICT-related Incident. Asset-Types: Business Process Key References: DORA RTS RMF A.23.2c
7.2 DOR.ICT.INC.ANL.003	A reaction (time from an IS alert to the beginning of the assessment of the IS alert/IS Event) and response (time to classify and assign an ICT-related Incident) to ICT-related Incidents must be ensured without undue delay (during and outside working hours) to ensure that the ICT-related Incident handling process is initiated promptly. Additionally, the resolution of IS alerts not leading to an ICT-related Incident must also be ensured. Asset-Types: Business Process Key References: DORA RTS RMF A.23.2c
7.3 DOR.ICT.INC.ANL.004	During the assessment phase of an ICT-related Incident, the following information must be assessed: Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.25
7.3.1 DOR.ICT.INC.ANL.005	The cause and who is responsible for the ICT-related Incident. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.25
7.3.2 DOR.ICT.INC.ANL.006	The scope of the ICT-related Incident. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.25
7.3.3 DOR.ICT.INC.ANL.007	The impact caused by the ICT-related Incident. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.25
7.3.4 DOR.ICT.INC.ANL.008	Relevance regarding notification to external authorities (e.g., due to regulatory requirements or on ad-hoc request of external authority). Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.25
7.3.5 DOR.ICT.INC.ANL.009	The possible effects on assets. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.25
7.3.6 DOR.ICT.INC.ANL.010	If necessary, involvement or forwarding of the ICT-related Incident to the crisis management and business continuity management units. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.25

7.4 DOR.ICT.INC.ANL.011	Based on the assessment phase, measures for the immediate remediation of the ICT-related Incident (short-term measures) must be defined. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.25
7.5 DOR.ICT.INC.ANL.012	Responsibilities and timelines must be determined and communicated to the relevant stakeholders. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.25
7.6 DOR.ICT.INC.ANL.012	All relevant stakeholders must be involved or informed during the ICT-related Incident handling to ensure that appropriate actions will be taken. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.25
7.7 DOR.ICT.INC.ANL.013	The ICT-related Incident investigation and diagnosis activity must be described in the ICT-related Incident Management process. Asset-Types: Business Process Key References: ICT Risk Framework 1.0

ID: 8 (version 2.0)	ICT-related Incident Regular Reporting
8 DOR.ICT.INC.REP.001	It must be ensured that ICT-related Incident Regular Reporting is established and in place.
8.1 DOR.ICT.INC.REP.002	Overview and the process of ICT-related Incidents must be reported to the relevant stakeholders based on the need-to-know principle at defined intervals and via standardized interfaces. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.26

ID: 9 (version 2.0)	ICT-related Incident Communication
9 DOR.ICT.INC.COM.001	There must be a procedure for the communication of ICT-related Incidents.
9.1 DOR.ICT.INC.COM.002	The existence of an ICT-related Incident or any relevant details thereof must be communicated to other internal and external people or organizations according to the ICT-related Incident communication plan on a need-to-know basis. Asset-Types: Business Process, Tool, Certificate, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.26
9.2 DOR.ICT.INC.COM.003	For each ICT-related Incident, an analysis must be performed to determine which relevant authorities require notification.

	Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.26
9.3 DOR.ICT.INC.COM.004	Where notification is required, relevant authorities must be notified in due time according to the communication plan and the incident's classification. Depending on the nature and impact of the incident, these authorities include, but are not limited to: – The Federal Financial Supervisory Authority (BaFin) – The Federal Office for Information Security (BSI) – The Federal Office for Civil Protection and Disaster Assistance (BBK) The Management Body, including LE CISO/Chief ICT Risk Office(s) of the impacted Legal Entities and Group CISO/Chief ICT Risk Officer must be informed without undue delay: Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.26
9.4 DOR.ICT.INC.COM.005	The Management Body, including LE CISO/Chief ICT Risk Office(s) of the impacted Legal Entities and Group CISO/Chief ICT Risk Officer must be informed without undue delay: Asset-Types: Business Process Key References: ICT Risk Framework 1.0
9.4.1 DOR.ICT.INC.COM.006	Occurrence of major ICT-related Incidents², including ad hoc evolving situations. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
9.4.2 DOR.ICT.INC.COM.007	ICT-related Incidents with a potentially high impact on ICT Systems supporting critical or important functions and services. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
9.5 DOR.ICT.INC.COM.008	It must be ensured that ICT-related Incidents affecting publicly available telecommunication network and/or offered telecommunication services are reported to <i>Bundesnetzagentur</i> and <i>BSI</i> in a timely manner. Asset-Types: Business Process, Tool, Certificate, Cloud PaaS, Network Connection Key References: TKG §169
9.6 DOR.ICT.INC.COM.009	It must be ensured that in case of ICT-related Incidents of publicly available telecommunication network and/or offered telecommunication services affecting personal data <i>Bundesnetzagentur</i> and <i>der Bundesbeauftragte für den Datenschutz und die Informationsfreiheit</i> are immediately notified. Asset-Types: Information, Business Process, Tool, Certificate, Cloud PaaS, Network Connection Key References: TKG §169

ID: 10 (version 2.0)	Major ICT-related Incident, Significant Cyber Threat and Recurring Incident Reporting
10 DOR.ICT.INC.MAJ.001	It must be ensured that a major ICT-related Incident and recurring ICT-related Incident reporting procedure is established and in place.
10.1 DOR.ICT.INC.MAJ.002	Major ICT-related Incidents ² that meet the threshold must be reported to the competent authorities and immediately to Management Body, including LE CISO(s) of the impacted Legal Entities and the Group CISO: Asset-Types: Business Process Key References: DORA 2022/2554 A.19.1
10.1.1 DOR.ICT.INC.MAJ.003	The competent authorities must be provided with an initial notification report as soon as possible, but no later than 4 hours after classifying an ICT-related Incident as major, and within 24 hours of becoming aware of the ICT-related Incident. Asset-Types: Business Process Key References: DORA 2022/2554 A.19.1, 19.4a)
10.1.2 DOR.ICT.INC.MAJ.004	An intermediate report must be submitted within 72 hours of the initial notification, detailing the updates on ICT-related Incident status, impact, and actions taken. Asset-Types: Business Process Key References: DORA 2022/2554 A.19.1
10.1.3 DOR.ICT.INC.MAJ.006	A final report must be submitted within 1 month after the last intermediate report, providing a full root cause analysis, impact, and actions taken. Asset-Types: Business Process Key References: DORA 2022/2554 A.19.1
10.1.4 DOR.ICT.INC.MAJ.007	If the time limits for submitting the initial notification, intermediate report, or final report cannot be met, the competent authority must be informed without undue delay, but no later than the respective time limits for the submission, and an explanation for the reasons of the delay must be provided. Asset-Types: Business Process Key References: DORA 2022/2554 A.19.1
10.2 DOR.ICT.INC.MAJ.008	For ICT-related Incidents to be reported under DORA, the requirements of ITS 2025/302, which describes standard forms, templates and procedures for reporting major ICT-related Incidents, must be followed. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.1.a), A.1.b), A.1.c), A.1.5), A.8.1, RTS 2025/301
10.3 DOR.ICT.INC.MAJ.009	Significant updates or changes in the ICT-related Incident's status must be reported immediately to the relevant stakeholders. Asset-Types: Business Process Key References: DORA 2022/2554 A.19.4.b)
10.4 DOR.ICT.INC.MAJ.010	It must be ensured that the information contained in the ICT-related Incident notification, interim, final report and update is complete and accurate. If there is no accurate data available, estimated values based on other available dates and information must be provided.

	Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.8.2
10.5 DOR.ICT.INC.MAJ.011	Upon the request of the competent authority, it must be ensured that the competent authority receives a report of an estimation of the total annual costs and losses resulting from major ICT-related Incidents ² . Asset-Types: Business Process Key References: DORA 2022/2554 A.11.10
10.6 DOR.ICT.INC.MAJ.012	It should be ensured that the competent authority is informed about significant cyber threats when these threats are relevant to the financial system, service users or clients. Asset-Types: Business Process Key References: DORA 2022/2554 A.19.2
10.7 DOR.ICT.INC.MAJ.013	Where the major ICT-related Incidents ² have an impact on the financial interests of clients, the clients must be informed without undue delay regarding the major ICT-related Incident and measures taken to mitigate adverse effects. Asset-Types: Business Process Key References: DORA 2022/2554 A.19.1
10.8 DOR.ICT.INC.MAJ.014	Recurring ICT-related Incidents that do not individually meet the criteria for a major ICT-related Incident ² but have a cumulative impact which must be tracked and reported in aggregate to the competent authorities. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.3
10.9 DOR.ICT.INC.MAJ.015	All communication and reporting of ICT-related Incidents, significant cyber threats, and recurring ICT-related Incidents to competent authorities and relevant stakeholders must be conducted through secure electronic channels. Asset-Types: Business Process, Tool, Certificate, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection, Supplier Key References: DORA RTS Major Incid. Class. A.4.1
10.10 DOR.ICT.INC.MAJ.016	If the established secure electronic channels cannot be used, the competent authorities must be notified without delay through previously agreed alternative channels. Asset-Types: Business Process, Supplier Key References: DORA RTS Major Incid. Class. A.4.2
10.11 DOR.ICT.INC.MAJ.017	If a third-party provider is outsourced for reporting, the competent authority must be informed before any first notification or reporting and the latest as soon as the outsourcing arrangement has been concluded. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.6
10.12 DOR.ICT.INC.MAJ.018	The name, contact details, and an identification code of the third-party, any third-party arrangement updates or cancelling of it must be provided to the competent authority. Asset-Types: Business Process Key References: DORA RTS Major Incid. Class. A.6

ID: 11 (version 2.0)	ICT-related Incident Response and Closure
11 DOR.ICT.INC.RSP.001	It must be ensured that ICT-related Incident Response and Closure is established and in place.
11.1 DOR.ICT.INC.RSP.002	Upon detection of an ICT-related Incident, a response must be initiated considering the following criteria: Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.26
11.1.1 DOR.ICT.INC.RSP.003	Implementation of the selected short-term measures within SLAs defined with the relevant legal entities. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.26
11.1.2 DOR.ICT.INC.RSP.004	Containment and / or recovery from an ongoing ICT-related Incident. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.26
11.1.3 DOR.ICT.INC.RSP.005	Handling the information security vulnerabilities and weakness(es) found to cause or contribute to the ICT-related Incident. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.26
11.1.4 DOR.ICT.INC.RSP.006	Escalation of the ICT-related Incidents if required. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.26
11.1.5 DOR.ICT.INC.RSP.007	Once the ICT-related Incident has been successfully dealt with, formally closing, and archiving it. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.26
11.2 DOR.ICT.INC.RSP.008	Procedures must be applied for the identification, collection, acquisition, and preservation of information, which can serve as evidence (for example in case of a jurisdiction case) as soon as possible after the occurrence. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.28
11.3 DOR.ICT.INC.RSP.009	Requirements regarding the usage of an external vendor for the outsourcing of a forensic investigation must be defined. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.28
11.4 DOR.ICT.INC.RSP.010	Evidence must be made available promptly to enable a forensic investigation and the collection of evidence, e.g., user mailbox, laptop. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device,

	Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.28
11.5 DOR.ICT.INC.RSP.011	Preservation of evidence must be documented, and a formal chain of custody must be completed for following up any transports or activities. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.28
11.6 DOR.ICT.INC.RSP.012	All incident-linked documentation must be securely archived for future reference, audits, and compliance purposes. Asset-Types: Information, Business Process, Storage Media, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.22 1d)
11.7 DOR.ICT.INC.RSP.013	The closure process must ensure that prior to undertaking disruptive or intrusive resolution activities appropriate measures are taken to ensure information security is maintained, configuration data is saved, and user access data is preserved. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ICT Risk Framework 1.0
11.8 DOR.ICT.INC.RSP.014	After recovering from an ICT-related Incident, through checks, including multiple verifications and reconciliations must be performed to ensure data integrity. These checks must be conducted when reconstructing data from external sources to ensure consistency across ICT Systems. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA 2022/2554 A.12.7

ID: 12 (version 2.0)	ICT-related Incident Lessons Learned
12 DOR.ICT.INC.ILL.001	It must be ensured that ICT-related Incident Lessons Learned procedures are established and in place.
12.1 DOR.ICT.INC.ILL.002	Lessons learned exercises must be performed and documented after an ICT-related Incident took place to achieve the following criteria: Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.27, DORA 2022/2554 A.13
12.1.1 DOR.ICT.INC.ILL.003	Improve the processes and procedures based on experiences from the ICT-related Incident to improve the handling of further ICT-related Incidents.

	Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.27, DORA 2022/2554 A.13
12.1.2 DOR.ICT.INC.ILL.004	Detect vulnerabilities and security problems to be mitigated and define measures to mitigate the risk of this ICT-related Incident to re-occur (long-term measures). Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.27, DORA 2022/2554 A.13
12.1.3 DOR.ICT.INC.ILL.005	Ensure the defined long-term measures are implemented. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.27, DORA 2022/2554 A.13
12.1.4 DOR.ICT.INC.ILL.006	Improve tool capabilities to prepare for future ICT-related Incidents. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.27, DORA 2022/2554 A.13
12.1.5 DOR.ICT.INC.ILL.007	Derive actionable insights into common ICT-related Incident scenarios. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.27, DORA 2022/2554 A.13
12.1.6 DOR.ICT.INC.ILL.008	Improve response, resumption, and recovery plans. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.27 Key References: ISO 27001:2022 Cor 202203 A.5.27, DORA 2022/2554 A.13
12.2 DOR.ICT.INC.ILL.009	The types, volumes, and costs of ICT-related Incidents should be monitored. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.27
12.3 DOR.ICT.INC.ILL.010	The information gained from the evaluation of ICT-related Incidents should be used to identify recurring or serious ICT-related Incident, determine additional controls and/or enhance user awareness and training. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.27
12.4 DOR.ICT.INC.ILL.011	The legal entity should maintain a record of past incidents to facilitate the diagnosis and resolution of future incidents with similar characteristics. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.27
12.5 DOR.ICT.INC.ILL.012	Communication with special interest groups to discuss information connected to ICT-related Incidents must take place according to existing obligations (e.g., regulatory, or contractual). Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.27
12.6 DOR.ICT.INC.ILL.013	Status of actions must be reported monthly to Group CISO / LE CISO, the executive board and any other relevant stakeholders. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.27
12.7 DOR.ICT.INC.ILL.014	Evidence on the progress made during the last 4 weeks must be provided or issues that prevented to make any progress must be reported.

	Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.27
12.8 DOR.ICT.INC.ILL.015	After a major ICT-related Incident², a post-ICT-related Incident review must be conducted to analyze the causes of the disruption and identify necessary improvements. Asset-Types: Business Process Key References: DORA 2022/2554 A.13.2
12.9 DOR.ICT.INC.ILL.016	The review must evaluate whether established procedures were followed and assess the effectiveness of actions taken, including: Asset-Types: Business Process Key References: DORA 2022/2554 A.13.2.a)
12.9.1 DOR.ICT.INC.ILL.017	Promptness: The speed of response to security alerts and the determination of the ICT-related Incident's impact and severity. Asset-Types: Business Process Key References: DORA 2022/2554 A.13.2.a)
12.9.2 DOR.ICT.INC.ILL.018	Forensic Analysis: The quality and speed of forensic analysis, if conducted. Asset-Types: Business Process Key References: DORA 2022/2554 A.13.2.b)
12.9.3 DOR.ICT.INC.ILL.019	ICT-related Incident Escalation and Communication: The effectiveness of the escalation process within the organization and the external/internal communication. Asset-Types: Business Process Key References: DORA 2022/2554 A.13.2.c), d)
12.10 DOR.ICT.INC.ILL.020	It must be ensured that ICT-related Incidents, patterns and trends are analyzed in terms of number and frequency to identify problems at an early stage. Asset-Types: Business Process Key References: DORA 2022/2554 A.13.4)

ID: 13 (version 2.0)	ICT Problem Management
13 DOR.ICT.INC.PBM.001	It must be ensured that ICT Problem Management is established and implemented.
13.1 DOR.ICT.INC.PBM.002	A process must be in place to identify, classify and resolve problems proactively and reactively. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
13.2 DOR.ICT.INC.PBM.003	Problems should be addressed and/or handed over to the responsible stakeholder in order of priority. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
13.3 DOR.ICT.INC.PBM.004	A ticket system must be used to record, classify, and prioritize problems, ensuring that criticality levels are assigned and tracked.

	Asset-Types: Business Process Key References: ICT Risk Framework 1.0
13.4 DOR.ICT.INC.PBM.005	ICT problems must be followed up on and resolved in a timely manner. If a problem is not resolved in a timely manner, an escalation process must be in place. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
13.5 DOR.ICT.INC.PBM.006	ICT-related Incident patterns and trends must be analyzed to identify the problems at an earlier stage. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
13.6 DOR.ICT.INC.PBM.007	ICT problems must be reported to the Management Body, including Group CISO, LE CISO(s) and ICT CROs of the impacted Legal Entities, and/or national authorities as needed. Asset-Types: Business Process Key References: ICT Risk Framework 1.0

ID: 14 (version 2.0)	ICT-related Incidents Platform and Tools
14 DOR.ICT.INC.PLT.001	It must be ensured that ICT-related Incidents Platform and Tools are established and in place.
14.1 DOR.ICT.INC.PLT.002	Tools enabling the handling of ICT-related Incidents must be implemented, configured, maintained, and documented. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.24
14.2 DOR.ICT.INC.PLT.003	The tools must at least offer tracking, handling, and secure storage of related information to the ICT-related Incident. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.24

5. Roles and Responsibilities

5.1. Creator

The creator of the ICT Incident & Operational Event Management Guideline is the **ICT Risk Governance & Advisory** Unit (Specialist).

The creator of the ICT Incident & Operational Event Management Guideline has the responsibility to issue clear, precise, and appropriate written rules to give guidance for implementation to the target group. It is important to ensure that all required information is accurate, up to date and complete.

5.2. Guideline Owner

The owner of the ICT Incident & Operational Event Management Guideline is Head of **ICT Risk Governance & Advisory** Unit.

The most important tasks (not an exhaustive list) within the scope of responsibility are:

- Ensure completeness of the Guideline within functional area of responsibility
- Ensure correctness of content and that the Guideline is up to date
- Define and conduct adherence oversight measures for Guidelines on a regular basis
- Assess impact on the Guideline with major focus on requirements as well as roles and responsibilities in the event of organizational changes, new products etc.

The Guideline Owner has at least an Expert or Head of Unit level.

The Guideline Owner is responsible for publishing and updating the ICT Incident & Operational Event Management Guideline according to established procedures within the organization.

6. Appendix

6.1. Contact Information

Written Rule Owner: Head of ICT Risk Governance & Advisory Unit

Please contact **ICT Risk Governance & Advisory** in case of any questions related to this Guideline.

6.2. Document History

Document History

Version	Date	Changes & Background
1.0	17.01.2025	Initial set-up of this Guideline
1.1	15.08.2025	Annual Update Guideline
2.0	19.08.2026	Annual Update with material changes

Coordination before publication

Version	Date	Task	Name
2.0	13.05.2026	Creator	ICT Risk Governance & Advisory Unit (Specialist)
	24.07.2026	Content Review	LE CISOs TISOs IT Ameli project
	24.07.2026	Content Confirmation	Head of ICT Risk Governance & Advisory Unit and LE CISOs

Approvals

Version	Date	Task	Name
2.0	13.08.2026	Approval	DBAG Chief Risk Officer

6.3. Related Written Rules

Superordinated Written Rules	ICT Risk Management Policy
Subordinated Written Rules	n/a

6.4. Abbreviations

The abbreviations in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

***** END OF DOCUMENT *****
